Red Stealer Lab

1. Kịch bản

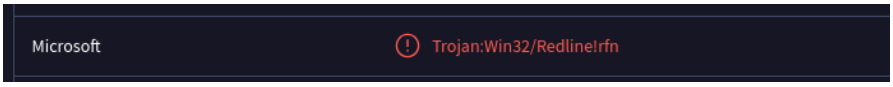
- Một file thực thi bị phát hiện, có khả năng liên quan C2 server → nghi ngờ bị nhiễm malware. Thu thập và phân tích dữ liệu từ file này cho SOC

2. Write up

- Hash: 248FCC901AFF4E4B4C48C91E4D78A939BF681C9A1BC24ADDC3551B32768F907B

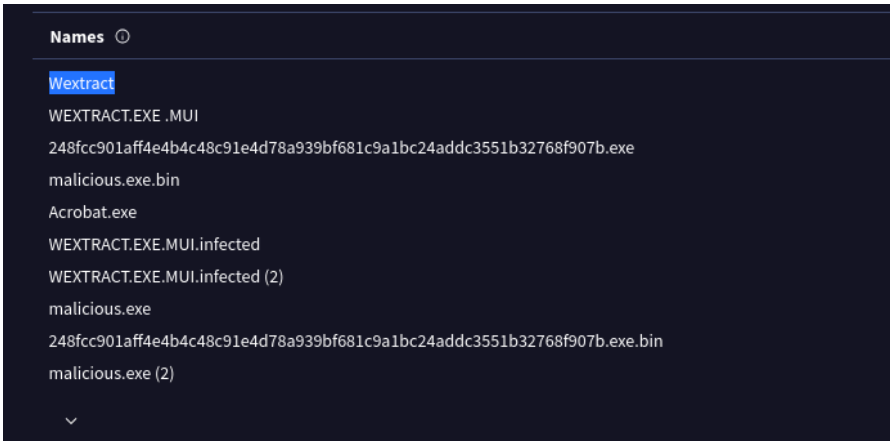
1. Categorizing malware enables a quicker and clearer understanding of its unique behaviors and attack vectors. What category has Microsoft identified for that malware in VirusTotal?

- Yêu cầu: xác định loại malware → hành vi và attack vector đặc trưng của nó
- As: Trojan
- Trên Virustotal, Microsoft phân loại malware là Trojan
  - Trojan: giả mạo phần mềm hợp lệ để lừa người dùng cài đặt nhằm thu thập thông tin, thả dropper, RAT,...



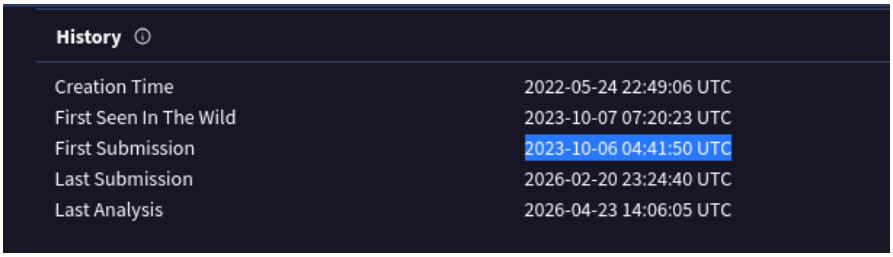
2. Clearly identifying the name of the malware file improves communication among the SOC team. What is the file name associated with this malware?

- Yêu cầu: Xác định filename của malware
- As: Wextract
- Truy cập vào phần Names để lấy thông tin về tên file



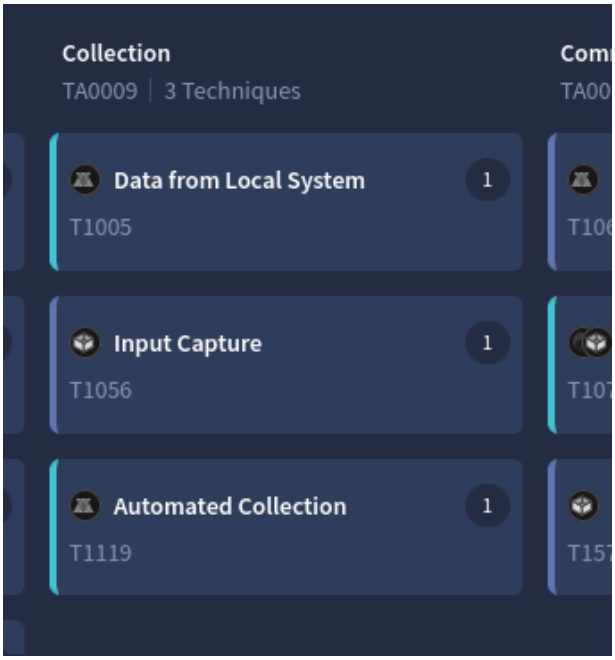
3. Knowing the exact timestamp of when the malware was first observed can help prioritize response actions. Newly detected malware may require urgent containment and eradication compared to older, well-documented threats. What is the UTC timestamp of the malware's first submission to VirusTotal?

- Yêu cầu: Tìm thời gian được phát hiện lần đầu của malware, các malware mới cần ngăn chặn và tiêu diệt khẩn cấp hơn
- As: 2023-10-06 04:41
- Đây là thời gian mà file được submit lần đầu và phân tích trên VirusTotal



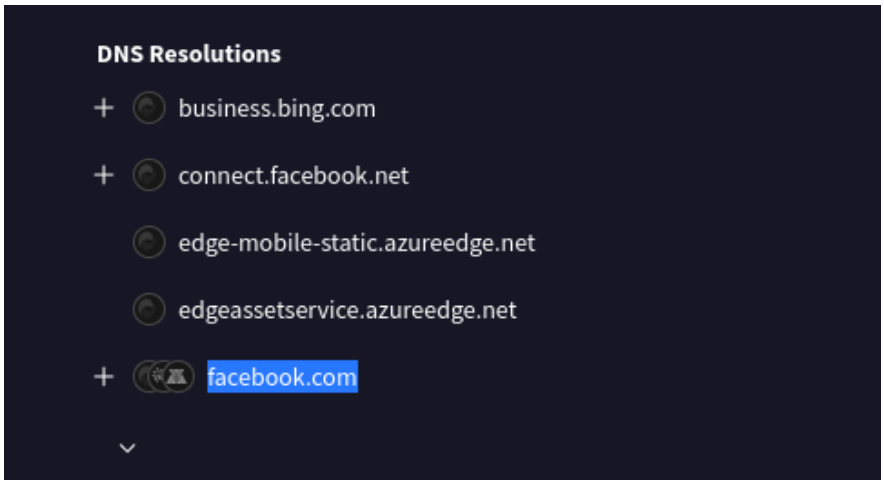
4. Understanding the techniques used by malware helps in strategic security planning. What is the MITRE ATT&CK technique ID for the malware's data collection from the system before exfiltration?

- Yêu cầu: Mitre ATTCK của kỹ thuật data collection của malware trước khi đánh cắp
- As: T1005
- Đây là kỹ thuật thu thập data từ Local System



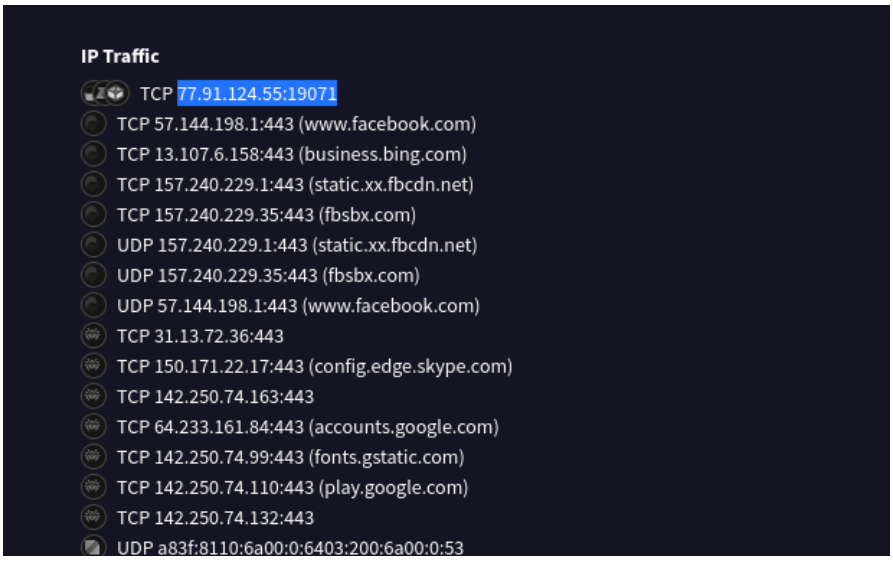
5. Following execution, which social media-related domain names did the malware resolve via DNS queries?

- Yêu cầu: tìm domain name liên quan đến mạng xã hội
- As: http://facebook.com/
- Kiểm tra mục DNS Resolutions → tìm được các domain đã được phân giải
- Việc malware truy cập tới tên miền uy tín này có thể là
  - Trộn lưu lượng mạng với lưu lượng hợp pháp để né tránh
  - Lợi dụng tính năng của các web lớn này để trung chuyển lệnh → C2 là tên miền lớn (ít bị chặn)
  - Ngụy trang tên miền uy tín làm vỏ bọc cho truy vấn đến C2



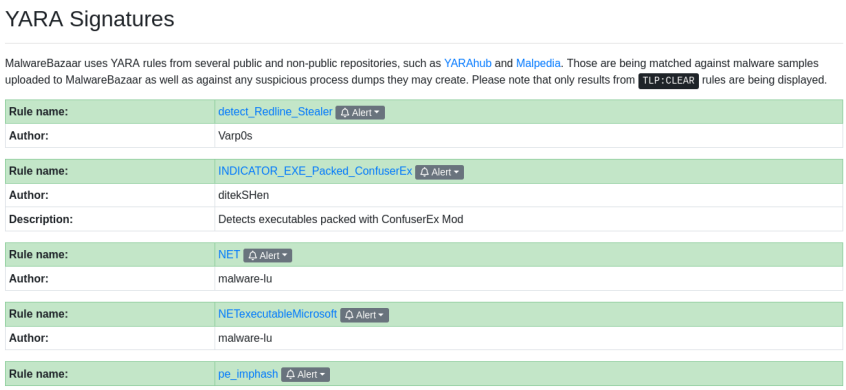
6. Once the malicious IP addresses are identified, network security devices such as firewalls can be configured to block traffic to and from these addresses. Can you provide the IP address and destination port the malware communicates with?

- Yêu cầu: xác định IP và port đích malware sử dụng để cấu hình chặn traffic
- As: 77.91.124.55:19071
- Mục IP Traffic có các danh sách IP, Port mà malware đã sử dụng
- Đối với C2 là IP → tìm các trafifc TCP ra Internet và trước đó không có DNS phân giải ra IP tương ứng



7. YARA rules are designed to identify specific malware patterns and behaviors. Using MalwareBazaar, what's the name of the YARA rule created by "`Varp0s`" that detects the identified malware?

- Yêu cầu: Sử dụng MalwareBazaar → mẫu và hành vi cụ thể của malware
- As: detect_Redline_Stealer
- MalwareBazaar: cung cấp một số rule đặc trưng để phát hiện malware



YARA Signatures

MalwareBazaar uses YARA rules from several public and non-public repositories, such as YARAhub and Malpedia. Those are being matched against malware samples uploaded to MalwareBazaar as well as against any suspicious process dumps they may create. Please note that only results from TLP:CLEAR rules are being displayed.

Rule name:	detect_Redline_Stealer Alert
Author:	Varp0s
Rule name:	INDICATOR_EXE_Packed_ConfuserEx Alert
Author:	ditekSHen
Description:	Detects executables packed with ConfuserEx Mod
Rule name:	NET Alert
Author:	malware-lu
Rule name:	NETexecutableMicrosoft Alert
Author:	malware-lu
Rule name:	pe_imphash Alert

- Dựa vào kết quả thu được, malware được đánh dấu là Redline Stealer
  - Malware này có khả năng thu thập thông tin từ nhiều nguồn trên máy tính bị nhiễm: web, app, ...
- YARA là quét tĩnh: nó tìm các signature nằm bên trong file thực thi như string, bộ API, DLL đặc trưng

8. Understanding which malware families are targeting the organization helps in strategic security planning for the future and prioritizing resources based on the threat. Can you provide the different malware alias associated with the malicious IP address according to **ThreatFox**?

- Yêu cầu: Tìm kiếm các họ malware nhắm vào tổ chức → lập kế hoạch và ưu tiên nguồn lực dựa trên IP độc hại tìm được
- As: RECORDSTEALER
- Tra theo cú pháp ioc:77.91.124.55 thu được malware alias là RECORDSTEALER
  - Tên được gán bởi nền tảng bảo mật khác → biết để hỗ trợ thu thập thông tin về mối đe dọa
  - Đối với báo cáo → cần chuẩn hóa: lấy tên phổ biến làm gốc và tên alias vào phần chú thích nếu có dữ liệu từ nguồn tương ứng

Database Entry

Actions

IOC ID:	1167880
IOC:	77.91.124.55:19071
IOC Type:	ip:port
Threat Type:	botnet_cc
Malware:	RedLine Stealer
Malware alias:	RECORDSTEALER
Confidence Level:	Confidence level is high (100%)
Is compromised?:	False
ASN:	AS203727 byon

9. By identifying the malware's imported DLLs, we can configure security tools to monitor for the loading or unusual usage of these specific DLLs. Can you provide the DLL utilized by the malware for privilege escalation?

- Yêu cầu: tìm các DLL malware import để cấu hình tool theo dõi việc tải và sử dụng
- As: advapi32.dll
- 2 DLL cốt lõi
  - kerner32.dll: quản lý bộ nhớ và tiến trình → liên quan process injection
    - `WriteProcessMemory`
  - advapi32.dll: quản lý bảo mật, reg, hệ thống → liên quan leo thang đặc quyền
    - DuplicateTokenEx

Modules

Images
c:\windows\syswow64\imm32.dll
c:\windows\syswow64\ole32.dll
c:\windows\syswow64\advapi32.dll
c:\windows\syswow64\sechost.dll

Previous 1 2 3 4 Next

- Access token: đối tượng bảo mật trong HDH (win) lưu thông tin xác thực và đặc quyền tiến trình/luồng
  - Bị lợi dụng để mạo danh, leo thang đặc quyền, truy cập trái phép tài nguyên